



# **CVE-2025-24477: HEAP-BASED BUFFER OVERFLOW VULNERABILITY IN FORTIOS**

---

## **Vairav CVE Report**

**Date: July 10, 2025**

**Vairav Cyber Threat Intelligence Team**

**Vairav Technology Security Pvt. Ltd.**

Thirbam Sadak 148

Baluwatar, Kathmandu

Phone: +977 4541540

Mobile: +977-9820105900

Email: [sales@vairavtech.com](mailto:sales@vairavtech.com)

## EXECUTIVE SUMMARY

A vulnerability, identified as **CVE-2025-24477**, has been discovered in **Fortinet FortiOS**, impacting the `cw_stad` daemon. This heap-based buffer overflow vulnerability can be exploited by an **authenticated attacker** to execute **arbitrary code or commands**. While it carries a **CVSSv3 score of 4.0 (Medium severity)**, the potential for **privilege escalation** makes it a serious risk for affected environments. If successfully exploited, the vulnerability may lead to **unauthorized system control or access**, particularly in wireless configurations.

## VULNERABILITY DETAILS

### CVE-2025-24477

- **Description:** This vulnerability is a **heap-based buffer overflow** in the `cw_stad` daemon, caused by improper handling of specially crafted requests. It is classified under CWE-122 (Heap-based Buffer Overflow). An attacker with valid authentication credentials can exploit this flaw to execute arbitrary code or system commands.
- **Impact:** Exploitation could result in privilege escalation, potentially allowing an attacker to take control of affected systems or interfere with their operation.
- **CVSS Score:** 4.0 (Medium)

## AFFECTED VERSIONS

**FortiOS** versions impacted include:

- FortiOS 7.6: Versions 7.6.0 through 7.6.1
- FortiOS 7.4: Versions 7.4.0 through 7.4.7
- FortiOS 7.2: Versions 7.2.4 through 7.2.11

The following models are impacted if configured as a wireless client:

- FWF\_80F\_2R\_3G4G\_DSL
- FWF\_80F\_2R
- FWF\_81F\_2R\_3G4G\_DSL
- FWF\_81F\_2R\_3G4G\_POE

- FWF\_81F\_2R
- FWF\_81F\_2R\_POE
- FWF\_90G\_2R
- FWF\_91G\_2R

## RECOMMENDED ACTIONS

### Patch & Upgrade:

Users are strongly advised to upgrade FortiOS to the following versions or later:

- For FortiOS 7.6.0 through 7.6.17: Upgrade to 7.6.3 or above
- For FortiOS 7.4.0 through 7.4.7: Upgrade to 7.4.8 or above
- For FortiOS 7.2.4 through 7.2.11: Upgrade to 7.2.12 or above

## ADDITIONAL SECURITY MEASURES

- **Audit User Access:** Review and minimize the number of users with authenticated access to the system.
- **Network Segmentation:** Isolate FortiWiFi devices, particularly those configured as clients, from sensitive infrastructure.
- **Monitor Logs:** Enable verbose logging and regularly review authentication attempts and system anomalies.
- **Limit Wireless Client Roles:** Avoid configuring vulnerable FortiWiFi models as wireless clients unless absolutely necessary.
- **Implement IDS/IPS:** Deploy intrusion detection/prevention systems to detect suspicious behavior linked to crafted request patterns.

## REFERENCES

- <https://www.fortiguard.com/psirt/FG-IR-25-026>
- <https://cybersecuritynews.com/fortios-buffer-overflow-vulnerability/>

## CONTACT US

**Vairav Technology Security Pvt. Ltd.**

**Cyber Defender from the land of Gurkha**

Thirbam Sadak 148, Baluwatar

Kathmandu, Nepal

Phone: +977-01-4541540

Mobile: +977-9820105900

Email: [sales@vairavtech.com](mailto:sales@vairavtech.com)

Website: <https://vairavtech.com>